Gozly

GUIDE DU DÉVELOPPEUR

La page de gestion d'une app Gozly

Règles de design, méthode d'intégration et résultats attendus.

Pour les développeurs et les agences

Novembre 2026

Au programme

Tout ce qu'il faut savoir pour que la page de gestion de ton app s'affiche bien dans Gozly et soit approuvée du premier coup.

1 Vue d'ensemble
Qui héberge quoi, et comment ça fonctionne

2 Le parcours d'une app
Du brouillon à l'approbation

3 Comment ta page est affichée
Le cadre, les paramètres et l'autorisation d'affichage

4 Vérifier le jeton
La sécurité de ton intégration, avec du code

5 Règles de design
7 règles, les couleurs et les formes à respecter

6 Comment tester ta page
L'aperçu dans ton espace développeur

7 Résultats attendus
Ce qu'on vérifie avant d'approuver

8 API et événements
Lire et écrire dans Gozly, limites et messages envoyés par Gozly

9 Refus et retrait
Ce qui n'est pas accepté

1 Vue d'ensemble

Une app publiée dans le magasin d'intégrations a une fiche (nom, description, permissions, prix, etc.). Elle peut aussi avoir une **page de gestion**: la page où le client règle son app, une fois installée.

1 Tu héberges la page

Gozly n'exécute jamais ton code. Il affiche ta page dans un cadre isolé.

2 Tu factures toi-même

Gozly ne touche à aucun paiement entre toi et tes clients.

3 On vérifie avant d'approuver

Toute modification d'une app approuvée la renvoie en révision.

2 Le parcours d'une app

État	Ce que ça veut dire
Brouillon	Tu prépares la fiche. Personne d'autre ne la voit. Tu peux utiliser l'aperçu de ta page.
En révision	Tu as soumis l'app. Gozly vérifie la fiche et ta page (voir la section 7).
Approuvée	L'app apparaît dans le magasin, avec ton nom comme développeur.
Refusée	Tu reçois un message qui explique pourquoi. Corrige, puis soumets de nouveau.

UNE APP GRATUITE PAR COMPTE

Un compte sans abonnement peut créer une seule app. Pour en publier d'autres, il faut au moins l'abonnement Opale.

3 Comment ta page est affichée

Quand un client ouvre ton app dans Gozly, ta page est chargée dans un cadre, à l'adresse indiquée dans ta fiche, avec quatre paramètres ajoutés à l'adresse:

Paramètre	Valeur	À quoi ça sert
`jeton`	Jeton signé (JWT)	Dit quelle entreprise ouvre la page. Valide 5 minutes. À vérifier absolument (section 4).
`theme`	`sombre` ou `clair`	Le thème du tableau de bord du client. Ta page doit s'y adapter.
`accent`	Une couleur, p. ex. `#3a37d1`	La couleur d'accent du client, pour le bouton principal.
`lang`	`fr` ou `en`	La langue du client.

Le cadre est isolé: il autorise les scripts, les formulaires et les fenêtres ouvertes à la demande du client, mais ta page ne peut **pas** naviguer la page de Gozly ni y accéder. L'adresse doit commencer par `https://`.

Pas de page? Utilise ton propre tableau de bord

Tu n'es pas obligé de créer une page de gestion. Si ton app se gère déjà depuis un tableau de bord sur ton propre site, indique son adresse dans le champ **« Lien vers ton tableau de bord »** de ta fiche. Tu peux aussi avoir les deux.

- Gozly affiche, sur la page de ton app, un bouton **« Ouvrir [nom de ton app] »**.
- Le bouton ouvre ton site dans un **nouvel onglet**.
- C'est la **seule** façon d'ouvrir un autre site depuis la page de ton app. Dans une page de gestion affichée dans Gozly, aucun lien ne peut quitter la page.
- L'adresse doit commencer par `https://`. Ta propre connexion (compte, mot de passe) se fait sur ton site, jamais dans Gozly.

Autoriser l'affichage dans Gozly

Ton serveur doit accepter d'être affiché dans le cadre de Gozly. Envoie cet en-tête HTTP sur ta page, et n'envoie **pas** `X-Frame-Options: DENY` ni `SAMEORIGIN`:

EN-TÊTE HTTP

```
Content-Security-Policy: frame-ancestors https://gozly.net https://www.gozly.net
```

4 Vérifier le jeton

ÉTAPE LA PLUS IMPORTANTE

Sans cette vérification, n'importe qui pourrait ouvrir ta page en prétendant être n'importe quelle entreprise.

Ce que contient le jeton

Un JWT signé avec l'algorithme **HS256**, avec la **clé de signature de ton app** (visible dans ta fiche, bouton « Afficher la clé de signature »). Garde-la secrète: elle reste sur ton serveur, jamais dans le code de ta page.

Champ	Valeur
`iss`	`gozly.net`
`aud`	L'identifiant de ton app chez Gozly
`sub`	L'identifiant de l'entreprise qui ouvre la page. C'est ce que tu utilises pour retrouver ses réglages.
`entreprise`	Le nom de l'entreprise
`apercu`	`true` pour un aperçu (toi ou Gozly qui regarde la page). Dans ce cas `sub` vaut `apercu` : n'enregistre rien de réel.
`iat`, `exp`	Date de création et d'expiration (5 minutes après)

Les étapes (côté serveur)

1. Lis le paramètre `jeton` de l'adresse.
2. Vérifie la signature avec ta clé et l'algorithme **HS256 uniquement**. Refuse tout autre algorithme, y compris `none`.
3. Vérifie que `exp` n'est pas dépassé et que `iss` vaut `gozly.net`.
4. Utilise `sub` comme identifiant de l'entreprise. Ne fais confiance à aucun autre paramètre de l'adresse pour savoir qui est le client.
5. Si une étape échoue, n'affiche rien de sensible: montre un message d'erreur simple.

Exemple en Node.js

JAVASCRIPT

```
import jwt from "jsonwebtoken";

app.get("/gestion", (req, res) => {
  try {
    const p = jwt.verify(req.query.jeton, process.env.CLE_GOZLY, {
      algorithms: ["HS256"],   // jamais d'autre algorithme
      issuer: "gozly.net",
    });
    const entrepriseId = p.sub;   // l'entreprise qui ouvre la page
    // ... charge les réglages de cette entreprise, puis affiche la page
  } catch {
    res.status(401).send("Lien expiré. Rouvre l'app depuis Gozly.");
  }
});
```

Exemple en Python

PYTHON

```
import jwt  # PyJWT

try:
    p = jwt.decode(jeton, CLE_GOZLY, algorithms=["HS256"], issuer="gozly.net",
                   options={"verify_aud": False})
    entreprise_id = p["sub"]
except jwt.PyJWTError:
    return "Lien expiré. Rouvre l'app depuis Gozly.", 401
```

À SAVOIR

Le jeton vit 5 minutes: ne le garde pas comme session. Après la vérification, crée ta propre session (cookie) pour les actions suivantes, avec les attributs `Secure`, `HttpOnly` et `SameSite=None` (ta page est dans un cadre).

5 Règles de design

La page de gestion doit avoir l'air d'une partie de Gozly, pas d'un autre site. Le client ne doit voir aucune « couture » entre le tableau de bord et ta page.

1 Design neutre

Fond transparent. Aucune bannière, couleur de fond ni dégradé. Pas de cadre décoratif.

2 Utilise le thème reçu

Lis `theme` et `accent`. Le bouton principal prend la couleur `accent`.

3 Aucun branding

Pas de logo, de publicité ni de promotion. Gozly affiche déjà le nom et l'icône de ton app.

4 Ni pop-up, ni redirection, ni lien externe

Aucun lien vers un autre site dans ta page. Pour renvoyer vers ton tableau de bord, utilise le bouton prévu par Gozly (section 3).

5 Ni mot de passe Gozly, ni paiement

Le jeton suffit pour identifier l'entreprise. La facturation se fait sur ton site, avec le bouton « Ouvrir ».

6 Langues et écrans

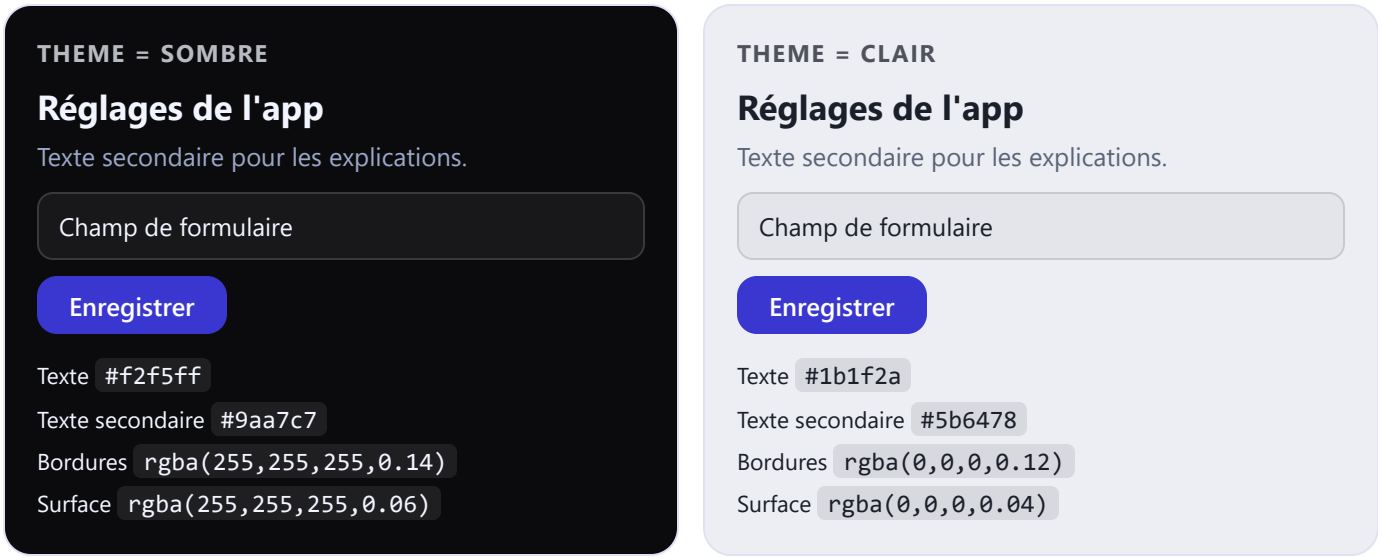
Français, et anglais si ton app l'est. Ordinateur et mobile (320 px au minimum).

7 Rapide et fiable

Utilisable en moins de 3 secondes. Si ton service est en panne, affiche un message clair, jamais une page blanche ni une erreur technique.

Les deux thèmes, côte à côte

Voici l'allure à viser. Ce sont des valeurs recommandées: ce qui compte, c'est que ta page ne jure pas avec le tableau de bord.



- **Bouton principal:** fond = `accent`, texte blanc.
- **Police:** `system-ui, -apple-system, "Segoe UI", sans-serif`. Pas de police décorative.
- **Texte:** 14 à 16 px. Titres de section: 16 à 20 px, en gras.
- **Formes:** coins arrondis (10 à 14 px), pas d'ombres lourdes ni de bordures épaisses.
- **Espacement:** marges de 16 à 24 px, contenu aligné à gauche.
- **Ton:** court et direct, avec « tu » (comme Gozly). Pas de longs paragraphes explicatifs.
- **Formulaires:** un champ par ligne, étiquette au-dessus, bouton d'enregistrement visible et message de confirmation après l'enregistrement.

6 Comment tester ta page

1. Dans ta fiche, indique l'adresse de ta page, coche la confirmation des règles et enregistre.
2. Clique sur **« Aperçu de ma page »**. Une fenêtre affiche ta page avec une entreprise de test, les boutons *Sombre / Clair* et *Bureau / Mobile*, et la liste des règles.
3. Teste les quatre combinaisons: sombre et clair, bureau et mobile.
4. Quand tout est bon, soumets l'app.

> **À SAVOIR**
> Dans l'aperçu, le jeton contient `apercu: true` et `sub: "apercu"`. Ne sauvegarde aucune donnée réelle pour cette entreprise de test.

7 Résultats attendus

Gozly ouvre ta page avec son outil d'aperçu et passe cette liste. Chaque ligne doit donner le résultat attendu.

Test	Résultat attendu
✓ **La page s'affiche dans le cadre**	Le contenu apparaît, sans erreur ni page blanche.
✓ **Thème sombre**	Fond transparent, texte clair lisible, aucune zone blanche.
✓ **Thème clair**	Fond transparent, texte foncé lisible, aucune zone noire.
✓ **Couleur d'accent**	Le bouton principal prend la couleur reçue.
✓ **Mobile (375 px)**	Aucun défilement horizontal, texte et boutons utilisables au doigt.
✓ **Langue**	Le français s'affiche. L'anglais aussi si l'app le prétend.
✓ **Branding**	Aucun logo, aucune publicité ni promotion.
✓ **Pop-ups et redirections**	Aucun, à l'ouverture comme pendant l'utilisation.
✓ **Liens vers un autre site**	Aucun dans ta page. Le seul passage vers ton site est le bouton « Ouvrir », qui s'ouvre dans un nouvel onglet.
✓ **Jeton invalide ou expiré**	Un message simple s'affiche, sans information sensible.
✓ **Service en panne**	Un message clair s'affiche, jamais une erreur technique.
✓ **Mot de passe et paiement**	La page ne demande jamais de mot de passe Gozly, ni de carte ou de paiement. La facturation se fait sur le site du développeur.
✓ **Rapidité**	La page est utilisable en moins de 3 secondes.

SI UN TEST ÉCHOUE

Ton app est refusée avec un message qui explique quoi corriger. Tu peux corriger et soumettre de nouveau autant de fois que nécessaire.

8 API et événements

Ton app peut lire (et parfois écrire) les données d'une entreprise qui l'a installée, dans la limite des **permissions déclarées dans ta fiche** et confirmées par le client à l'installation. Dans l'autre sens, Gozly peut t'envoyer des messages quand quelque chose arrive.

Ta clé d'API

Une fois ton app approuvée, génère ta clé dans ta fiche (bouton « Générer une clé »). Elle commence par `gozly_app_` et **ne s'affiche qu'une seule fois**: copie-la tout de suite. En générer une nouvelle désactive l'ancienne. Garde-la sur ton serveur, jamais dans une page ou une application mobile.

Appeler l'API

Toutes les requêtes vont à `https://gozly.net/api/v1/outils` et portent deux en-têtes:

En-tête	Valeur
`Authorization`	`Bearer` suivi de ta clé d'API
`X-Gozly-Entreprise`	L'identifiant de l'entreprise (le champ `sub` du jeton, section 4). Elle doit avoir installé ton app.

- **GET** renvoie la liste des outils que ton app a le droit d'utiliser.
- **POST** avec `{ "outil": "lire_inventaire", "args": { } }` exécute un outil et renvoie `{ "resultat": ... }`.

JAVASCRIPT

```
const res = await fetch("https://gozly.net/api/v1/outils", {
  method: "POST",
  headers: {
    "Authorization": "Bearer " + process.env.CLE_API_GOZLY,
    "X-Gozly-Entreprise": entrepriseId,
    "Content-Type": "application/json",
  },
  body: JSON.stringify({ outil: "lire_inventaire", args: { stock_bas: true } }),
});
const { resultat } = await res.json();
```

Outils et permissions

Un outil n'est permis que si la permission correspondante est dans ta fiche. Les outils « de base » sont permis dès que ton app a au moins une permission.

Outil	Permission	Ce qu'il fait
`lister_employes`, `lister_emplacements`	Toute permission	Noms et rôles des employés (jamais de salaire, de NIP ni de coordonnées); succursales.
`lire_horaire`, `lire_heures_pointees`	`horaire:lire`	Quarts de travail et heures pointées d'une période (62 jours au maximum).
`creer_quart_brouillon`, `supprimer_quart_brouillon`	`horaire:brouillons`	Quarts en brouillon, invisibles des employés.
`publier_horaire`	`horaire:publier`	Publie les brouillons; les employés sont notifiés.
`lister_categories_planning`, `lire_planning`	`planning:lire`	Catégories et tâches du Planning.
`creer_taches_planning`	`planning:creer`	Ajoute des tâches (visibles tout de suite).
`supprimer_tache_planning`	`planning:supprimer`	Supprime seulement les tâches créées par une IA ou une app.
`lire_inventaire`	`inventaire:lire`	Produits, quantités et seuils d'alerte.
`lire_ventes`	`ventes:lire`	Journal des ventes d'une période, avec totaux par source.

Le détail des arguments de chaque outil est renvoyé par le **GET**. Ne demande que les permissions dont ton app a vraiment besoin: le client les voit avant d'installer.

Limites

Une app mal faite ne doit pas ralentir les autres. Par défaut:

Limite	Valeur par défaut
Par entreprise	30 requêtes par minute
Pour toute ton app	120 requêtes par minute, 5 000 par jour

- Quand une limite est dépassée, Gozly répond `429` avec l'en-tête `Retry-After` (en secondes). Attends avant de réessayer.
- Si ton app dépasse sa limite par minute **plus de cinq fois**, elle est **suspendue automatiquement** (réponse `403`). Écris au support de Gozly pour la faire réactiver.
- Évite d'interroger Gozly sans arrêt: attends les messages de Gozly (ci-dessous) puis lis seulement ce qui a changé. Garde les réponses en mémoire quand c'est possible.
- Des limites plus élevées peuvent être accordées à une app qui en a besoin: écris au support.

Code	Signification
`400`	Demande invalide ou outil inconnu, ou permission manquante dans ta fiche.
`401`	Clé d'API manquante, invalide ou remplacée.
`403`	App non approuvée, suspendue, ou entreprise qui n'a pas installé l'app.
`429`	Trop de requêtes. Voir `Retry-After`.

Messages envoyés par Gozly

Quand quelque chose arrive, Gozly envoie **un seul message** à l'adresse du service de ta fiche (méthode `POST`, JSON, `https` obligatoire). Il ne contient aucune donnée personnelle: c'est un avertissement, tu viens ensuite lire ce qui a changé avec l'API. Un message n'est envoyé qu'aux apps qui ont la permission de lecture du module concerné.

Événement	Quand
`inventaire.synchronise`	Après une synchronisation de l'inventaire Wix. Permission requise: `inventaire:lire`. D'autres événements s'ajouteront.

CORPS DU MESSAGE

```
{
  "evenement": "inventaire.synchronise",
  "entreprise_id": "…",
  "date": "2026-11-12T15:04:05.000Z",
  "donnees": { "produits": 42 }
}
```

Le message porte l'en-tête `X-Gozly-Evenement` et une signature dans `X-Gozly-Signature` : `sha256=` suivi du HMAC-SHA256 du corps, calculé avec la **clé de signature de ton app** (la même que pour le jeton). Vérifie-la avant de faire confiance au message.

JAVASCRIPT

```
import crypto from "crypto";

// corpsBrut = le corps exact reçu, avant tout JSON.parse
const attendue = "sha256=" +
  crypto.createHmac("sha256", process.env.CLE_GOZLY).update(corpsBrut).digest("hex");
const recue = req.headers["x-gozly-signature"] || "";
const valide = recue.length === attendue.length &&
  crypto.timingSafeEqual(Buffer.from(recue), Buffer.from(attendue));
```

- Réponds avec un code `2xx` en moins de 5 secondes. Fais le travail lourd après avoir répondu.
- Gozly **ne réessaie pas** un message qui échoue: rattrape-toi avec l'API quand ton service redémarre.

9 Refus et retrait

- Une page qui ne respecte pas les règles de la section 5.
- Un jeton non vérifié, ou une page qui montre les données d'une entreprise à une autre.
- Un lien vers un autre site dans ta page, autre que le bouton « Ouvrir » prévu par Gozly.
- Une page qui demande des identifiants Gozly ou collecte des données au-delà des permissions déclarées dans la fiche.
- Une page ou un service qui cesse de fonctionner. Gozly peut alors retirer l'app du magasin.
- Une app qui abuse de l'API (dépassements répétés des limites): elle est suspendue.

SI TU SUPPRIMES TON COMPTE

Tu choisis de retirer tes apps ou de les laisser en ligne. Si tu les laisses, tu t'engages à garder ton service en ligne, ou à ce que l'app fonctionne sans mise à jour de ta part. Les clients qui l'ont déjà installée la gardent, mais l'app n'est plus proposée à de nouveaux clients.

En résumé

1. Héberge ta page en `https` et autorise `gozly.net` à l'afficher (`frame-ancestors`).
2. Vérifie le `jeton` (HS256, `exp` , `iss`) avant d'afficher quoi que ce soit.
3. Adapte-toi au `theme` , à l' `accent` et à la `lang` , sur fond transparent.
4. Pas de logo, de pub, de pop-up, de redirection, de lien externe, de mot de passe Gozly ni de paiement.
5. Pas de page? Indique le lien de ton tableau de bord: Gozly affiche un bouton « Ouvrir » (nouvel onglet).
6. Teste avec l'aperçu (sombre, clair, bureau, mobile), puis soumets.
7. API: clé d'API en `Bearer` + `X-Gozly-Entreprise` , 30 requêtes par minute par entreprise, `429` = attends. Vérifie la signature des messages de Gozly.